



# Website Vulnerabilities and Nikto

Nikto is an open source Web server vulnerability scanner that performs comprehensive tests for over 6,100 potentially dangerous files/CGIs, checks for outdated versions of over 950 servers, and for version-specific problems on over 260 servers. This article outlines a scenario where Nikto is used to test a company's Web server for vulnerabilities.

*A*s detailed by [www.cirt.net/Nikto2](http://www.cirt.net/Nikto2), Nikto, written by Chris Sullo and David Lodge, also checks for server configuration items, such as the presence of multiple index files and HTTP server options, and it attempts to identify installed Web servers and software. Scan items and plug-ins are frequently updated, and can be automatically updated on your system. Nikto also supports libWhisker's anti-IDS methods in case you want to test your IDS system. It is available for almost all flavours of Linux, as well as for Microsoft Windows and Mac OS.

## A tale of a website attack

Shree is the CEO of a small business with a global clientele. Early one morning, he received an urgent call from one of his employees, who told him that the company website, which many of Shree's clients used regularly for business, was being identified by Firefox as a "reported attack page" (Figure 1).

It appeared that the Web server had been cracked, and was now serving malware to visitors, including Shree's clients! Worried about the fallout, Shree made an emergency call to his website developers, who immediately brought down the site, and restored a clean back-up onto it. For a few hours, things were OK—but then, the site again began to exhibit the same problem. Shree was now a really worried man—the future of his business was at stake.

At this point, he called in his long-time friend, Kedar, a Web security expert, for emergency help. Kedar rushed to Shree's office and took charge of the situation. His primary intention was to restore the website to normalcy as soon as possible, while he promised to explain the incident after the site was up again.

Kedar took the precaution of downloading a copy of the compromised website to a local PC at the developer's office for scanning. (Under Indian cyber law and its amendments, running any scans, including a port scan, against